

■ DC-02 – 4.4.1 Brute-Force-Urbildsuche

Satz 4.1

Es sei p die Wahrscheinlichkeit, bei der Beobachtung von r unabhängigen Ereignissen aus einer Menge von insgesamt n möglichen gleichwahrscheinlichen Ereignissen, ein vorgegebenes Ereignis mindestens einmal zu beobachten.

(Urnenmodell: Wahrscheinlichkeit, dass beim Ziehen mit Zurücklegen aus einer Urne mit insgesamt n Kugeln spätestens nach r Versuchen eine bestimmte Kugel gezogen wird.)
(Anzahl möglicher Hashwerte) *vorgegebener Hashwert h*

Dann gilt:

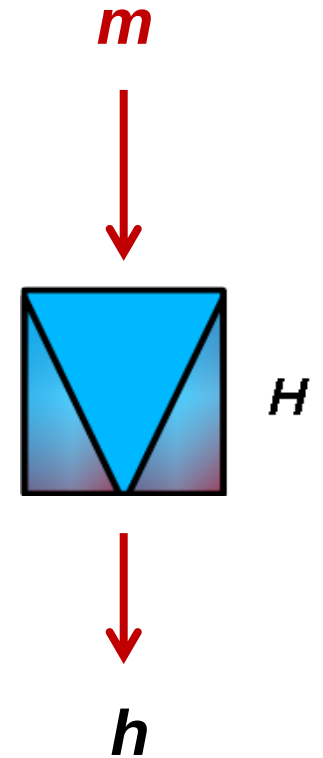
(i)

$$p = 1 - \left(1 - \frac{1}{n}\right)^r$$

Entgegengesetztes Ereignis: r Ziehungen ohne Erfolg:

$$\underbrace{(n-1) \cdot (n-1) \cdot (n-1) \cdot \dots \cdot (n-1)}_{\substack{1 \quad 2 \quad 3 \quad \dots \quad r}}$$

$$\frac{(n-1)^r}{n^r} = \left(\frac{n-1}{n}\right)^r = \left(1 - \frac{1}{n}\right)^r$$



Satz 4.1

Es sei p die Wahrscheinlichkeit, bei der Beobachtung von r unabhängigen Ereignissen aus einer Menge von insgesamt n möglichen gleichwahrscheinlichen Ereignissen, ein vorgegebenes Ereignis mindestens einmal zu beobachten.

Dann gilt:

(i) ✓

$$p = 1 - \left(1 - \frac{1}{n}\right)^r$$

(ii) Ist $n \geq 2$ und $p_0 \in (0, 1)$, so ist $p \geq p_0$ genau dann falls gilt:

$$r \geq \frac{\ln(1 - p_0)}{\ln(1 - \frac{1}{n})}$$

Vergleiche p_0 , z.B. $p_0 = 0,9$

(iii) Ist $n \geq 2$ und $p_0 \in (0, 1)$, so ist $p \geq p_0$ falls gilt:

$$r \geq |\ln(1 - p_0)| \cdot n$$

(iii)

↓ $p_0 = 0,5$

(iv)

(iv) Ist $n \geq 2$, so ist $p \geq \frac{1}{2}$ falls gilt:

$$r \geq \ln(2) \cdot n \approx 0,69315 \cdot n$$

(ii) Ist $n \geq 2$ und $p_0 \in (0, 1)$, so ist $p \geq p_0$ genau dann falls gilt:

$$r \geq \frac{\ln(1 - p_0)}{\ln(1 - \frac{1}{n})}$$

Ist $p \geq p_0$ so folgt mit (i):

$$p_0 \leq p \stackrel{(i)}{=} 1 - \left(1 - \frac{1}{n}\right)^r$$

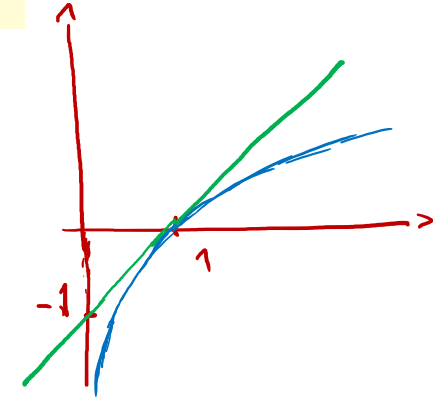
$$\Leftrightarrow \left(1 - \frac{1}{n}\right)^r \leq 1 - p_0$$

$$\Leftrightarrow r \ln \left(1 - \frac{1}{n}\right) \leq \ln(1 - p_0)$$

$$\Leftrightarrow r \geq \frac{\ln(1 - p_0)}{\ln \left(1 - \frac{1}{n}\right)}$$

(iii) Ist $n \geq 2$ und $p_0 \in (0, 1)$, so ist $p \geq p_0$ falls gilt:

$$r \geq |\ln(1 - p_0)| \cdot n$$



Allgemein gilt für alle $x \in \mathbb{R}^+$:

$$\ln(x) \leq x - 1$$

Insbesondere gilt für $n \geq 2$

$$\ln\left(1 - \frac{1}{n}\right) \leq -\frac{1}{n} \quad \Rightarrow \quad \left|\ln\left(1 - \frac{1}{n}\right)\right| \geq \frac{1}{n} \quad \Rightarrow \quad \frac{1}{\left|\ln\left(1 - \frac{1}{n}\right)\right|} \leq n$$

und deshalb:

$$\frac{\ln(1 - p_0)}{\ln\left(1 - \frac{1}{n}\right)} = \frac{|\ln(1 - p_0)|}{\left|\ln\left(1 - \frac{1}{n}\right)\right|} \leq |\ln(1 - p_0)| \cdot n \leq r$$

$$r \geq |\ln(1 - p_0)| \cdot n \quad \Rightarrow \quad r \geq \frac{\ln(1 - p_0)}{\ln\left(1 - \frac{1}{n}\right)} \stackrel{(\text{ii})}{\Rightarrow} p \geq p_0$$

Beispiel 4.7

Wieviele Menschen müssen nach ihrem Geburtstag gefragt werden, damit mit einer Wahrscheinlichkeit $p \geq \frac{1}{2}$ mindestens einer der Befragten an einem 14. Mai geboren wurde?

■ DC-02 – 4.4.2 Brute-Force-Kollisionssuche

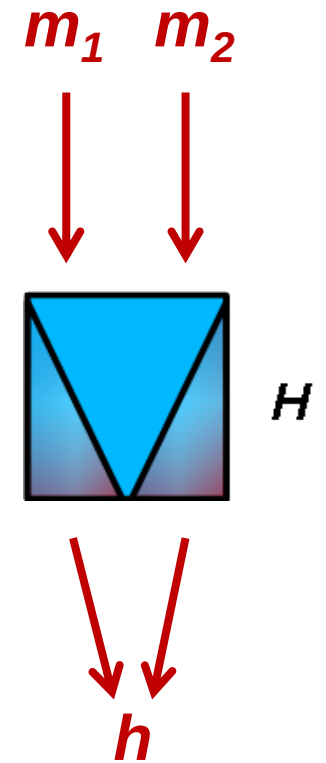
Satz 4.2

Es sei $p = p(n, r)$ die Wahrscheinlichkeit bei der Beobachtung von r unabhängigen Ereignissen aus einer Menge von insgesamt n möglichen gleichwahrscheinlichen Ereignissen, lauter verschiedene Ereignisse zu beobachten.

(Urnenmodell: Wahrscheinlichkeit, dass beim r -maligen Ziehen mit anschließendem Zurücklegen einer Kugel aus einer Urne mit insgesamt n Kugeln lauter verschiedene Kugeln gezogen werden.)

Dann gilt:

$$p(n, r) = \frac{n \cdot (n-1) \cdots (n-r+1)}{n^r} = \left(1 - \frac{1}{n}\right) \cdots \left(1 - \frac{r-1}{n}\right) \leq e^{-\frac{r(r-1)}{2n}}$$



$$\frac{n}{1} \cdot \frac{(n-1)}{2} \cdot \frac{(n-2)}{3} \cdots \frac{(n-r+1)}{r}$$

$$p(n, r) = \frac{n(n-1) \cdots (n-r+1)}{n^r} = \frac{n}{n} \cdot \frac{n-1}{n} \cdots \frac{n-r+1}{n} = \left(1 - \frac{1}{n}\right) \cdots \left(1 - \frac{r-1}{n}\right)$$

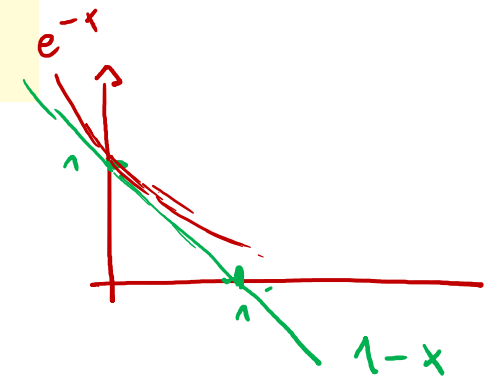
Satz 4.2

Es sei $p = p(n, r)$ die Wahrscheinlichkeit bei der Beobachtung von r unabhängigen Ereignissen aus einer Menge von insgesamt n möglichen gleichwahrscheinlichen Ereignissen, lauter verschiedene Ereignisse zu beobachten.

Dann gilt:

$$p(n, r) \stackrel{\checkmark}{=} \frac{n \cdot (n-1) \cdots (n-r+1)}{n^r} \stackrel{\checkmark}{=} \left(1 - \frac{1}{n}\right) \cdots \left(1 - \frac{r-1}{n}\right) \leq e^{-\frac{r(r-1)}{2n}}$$

$$\underline{1-x} \leq e^{-x} \quad \text{f. a. } x \in \mathbb{R}$$



$$\prod_{i=1}^{r-1} \left(1 - \frac{i}{n}\right) \leq \prod_{i=1}^{r-1} e^{-\frac{i}{n}} = e^{-\sum_{i=1}^{r-1} \frac{i}{n}} = e^{-\frac{1}{n} \sum_{i=1}^{r-1} i} = e^{-\frac{1}{n} \frac{r \cdot (r-1)}{2}}$$

Satz 4.3

Für die Kollisionswahrscheinlichkeit $p = c(n, r)$ gilt:

(i)

✓ (Satz 4.2)
↓

$$1 - e^{-\frac{r(r-1)}{2n}} \leq c(n, r) \leq \frac{r(r-1)}{2n}$$

(ii) Ist $r \leq \sqrt{2n}$, so gilt:

$$\left(1 - \frac{1}{e}\right) \cdot \frac{r(r-1)}{2n} \leq c(n, r) \leq \frac{r(r-1)}{2n}$$

(iii) Ist $p_0 \in (0, 1)$, so ist $c(n, r) \geq p_0$ falls gilt:

$$r \geq \sqrt{-2 \cdot \ln(1 - p_0)} \cdot \sqrt{n} + 1$$

(iv) Ist $p_0 \in (0, 1)$, so ist $c(n, r) \geq p_0$ falls gilt:

$$r \geq \sqrt{-2 \cdot \ln(1 - p_0) \cdot n + \frac{1}{4}} + \frac{1}{2}$$

(v) Es ist $c(n, r) \geq \frac{1}{2}$ falls

$$r \geq \sqrt{\ln(4)} \cdot \sqrt{n} + 1 \approx 1,18 \cdot \sqrt{n} + 1$$

oder die etwas schärfere Ungleichung

$$r \geq \sqrt{\ln(4) \cdot n + \frac{1}{4}} + \frac{1}{2}$$

$$C(n, r) = 1 - p(n, r) \geq 1 - e^{-\frac{r(r-1)}{2n}}$$

(i)

$$1 - e^{-\frac{r(r-1)}{2n}} \leq c(n, r) \leq \frac{r(r-1)}{2n}$$



$\bar{E}_i$: Erste Kollision nach i Ziehungen

$$c(n, r) = \Pr(\bar{E}_1 \cup \bar{E}_2 \cup \dots \cup \bar{E}_r) = \sum_{i=1}^r \Pr(\bar{E}_i) \leq \sum_{i=1}^r \frac{i-1}{n} = \frac{1}{n} \sum_{i=0}^{r-1} i = \frac{1}{n} \cdot \frac{r(r-1)}{2}$$

$\Pr(\bar{E}_i)$:

$$\underbrace{1}_{1} \underbrace{\quad}_{n-1} \dots \underbrace{\quad}_{i-1} \underbrace{\quad}_{i-1}$$

$$\begin{aligned} \Pr(\bar{E}_i) &= \frac{n \cdot (n-1) \cdot \dots \cdot (n-i+1) \cdot (i-1)}{n^r} \\ &= \underbrace{\frac{n(n-1) \cdot \dots \cdot (n-i+1)}{n^{i-1}}}_{\leq 1} \cdot \frac{(i-1)}{n} \\ &\leq \frac{i-1}{n} \end{aligned}$$

(i)

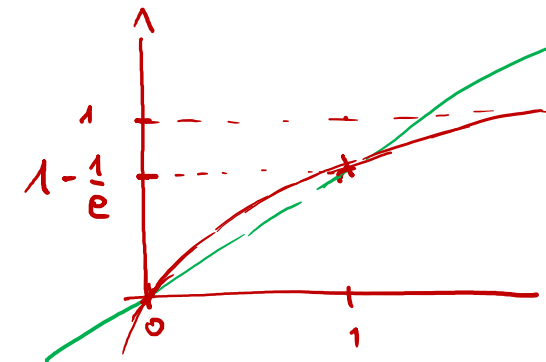
$$1 - e^{-\frac{r(r-1)}{2n}} \leq c(n, r) \leq \frac{r(r-1)}{2n}$$

(ii) Ist $r \leq \sqrt{2n}$, so gilt:

$$\left(1 - \frac{1}{e}\right) \cdot \frac{r(r-1)}{2n} \leq c(n, r) \leq \frac{r(r-1)}{2n}$$

Es gilt allgemein $\left(1 - \frac{1}{e}\right) \cdot x \leq 1 - e^{-x}$ f.a. $x \in [0, 1]$

Damit folgt (ii) aus (i) $\square$



(i)

$$p_0 \leq \underline{\underline{1 - e^{-\frac{r(r-1)}{2n}}} \leq c(n, r) \leq \frac{r(r-1)}{2n}}$$

(iii) Ist $p_0 \in (0, 1)$, so ist $c(n, r) \geq p_0$ falls gilt:

$$r \geq \sqrt{-2 \cdot \ln(1 - p_0)} \cdot \sqrt{n} + 1$$

Vorgabe: p_0

$$p_0 \leq 1 - e^{-\frac{r(r-1)}{2n}}$$



$$e^{-\frac{r(r-1)}{2n}} \leq 1 - p_0$$

$$-\frac{r(r-1)}{2n} \leq \ln(1 - p_0)$$

$$r(r-1) \geq -2 \ln(1 - p_0) \cdot n$$



$$r-1 \geq \sqrt{-2 \ln(1 - p_0)} \cdot \sqrt{n}$$



$$(r-1)^2 \geq -2 \ln(1 - p_0) \cdot n$$

(i)

$$p_0 \leq \underline{\underline{1 - e^{-\frac{r(r-1)}{2n}}} \leq c(n, r) \leq \frac{r(r-1)}{2n}}$$

(iv) Ist $p_0 \in (0, 1)$, so ist $c(n, r) \geq p_0$ falls gilt:

$$r \geq \sqrt{-2 \cdot \ln(1 - p_0) \cdot n + \frac{1}{4}} + \frac{1}{2}$$

Vorgabe: p_0

$$p_0 \leq 1 - e^{-\frac{r(r-1)}{2n}}$$

$$e^{-\frac{r(r-1)}{2n}} \leq 1 - p_0$$

$$-\frac{r(r-1)}{2n} \leq \ln(1 - p_0)$$

$$\begin{aligned} r^2 - r + \frac{1}{4} &= r(r-1) \geq -2 \ln(1 - p_0) \cdot n + \frac{1}{4} \quad \Rightarrow \quad r - \frac{1}{2} \geq \sqrt{-2 \ln(1 - p_0) \cdot n + \frac{1}{4}} \\ \left(r - \frac{1}{2}\right)^2 & \end{aligned}$$

(iii) Ist $p_0 \in (0, 1)$, so ist $c(n, r) \geq p_0$ falls gilt:

$$r \geq \sqrt{-2 \cdot \ln(1 - p_0)} \cdot \sqrt{n} + 1$$

(iv) Ist $p_0 \in (0, 1)$, so ist $c(n, r) \geq p_0$ falls gilt:

$$r \geq \sqrt{-2 \cdot \ln(1 - p_0) \cdot n + \frac{1}{4}} + \frac{1}{2}$$


 $p_0 = \frac{1}{2}$

(v) Es ist $c(n, r) \geq \frac{1}{2}$ falls

$$r \geq \sqrt{\ln(4)} \cdot \sqrt{n} + 1 \approx 1,18 \cdot \sqrt{n} + 1$$

oder die etwas schärfere Ungleichung

$$r \geq \sqrt{\ln(4) \cdot n + \frac{1}{4}} + \frac{1}{2}$$

gilt.

Beispiel 4.8

Wieviele Kinder müssen mindestens in einer Klasse sein, damit mit einer Wahrscheinlichkeit $p \geq \frac{1}{2}$ mindestens zwei der Kinder am gleichen Tag im Jahr ihren Geburtstag feiern?

s. Studienheft

Kompressionsfunktion

$$f : \mathbb{Z}_2^{r+s} \rightarrow \mathbb{Z}_2^s$$

← Zustandsraum

r : "Blocklänge"

Ausgabefunktion

$$g : \mathbb{Z}_2^s \rightarrow \mathbb{Z}_2^l$$

- Für die Nachricht m werden mit einem definierten Paddingverfahren Padding-Bits pad bestimmt, die nur von der Länge von m abhängen und für die gilt: $l(m || pad) = l(m) + l(pad)$ ist ein Vielfaches von r .

- $m || pad$ wird in Blöcke $m_1, \dots, m_n$ zerlegt, die alle r Bit lang sind:

$$m || pad(m) = m_1 || m_2 || \dots || m_n \quad \text{mit } l(m_1) = \dots = l(m_n) = r$$

- In Abhängigkeit von den Blöcken m_i wird der mit t_0 initialisierte Wert des Zustandsregisters iterativ unter Anwendung der Kompressionsfunktion neu berechnet:

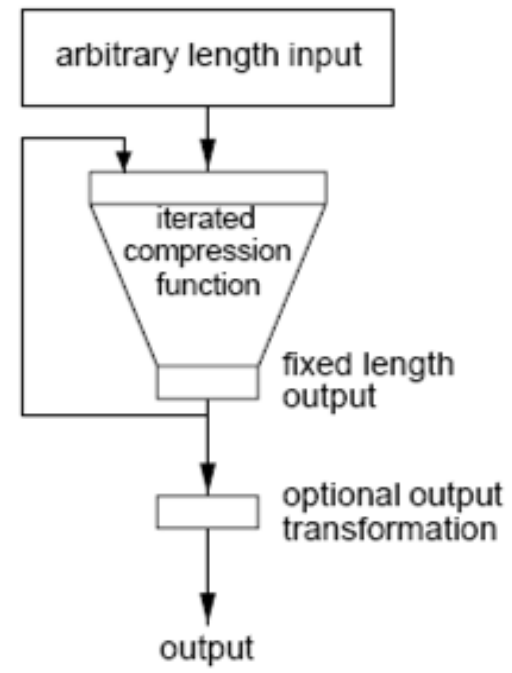
$$t_i := f(m_i || t_{i-1}) \quad \text{für } i = 1, 2, \dots, n$$

$$t_i \in \mathbb{Z}_2^s$$

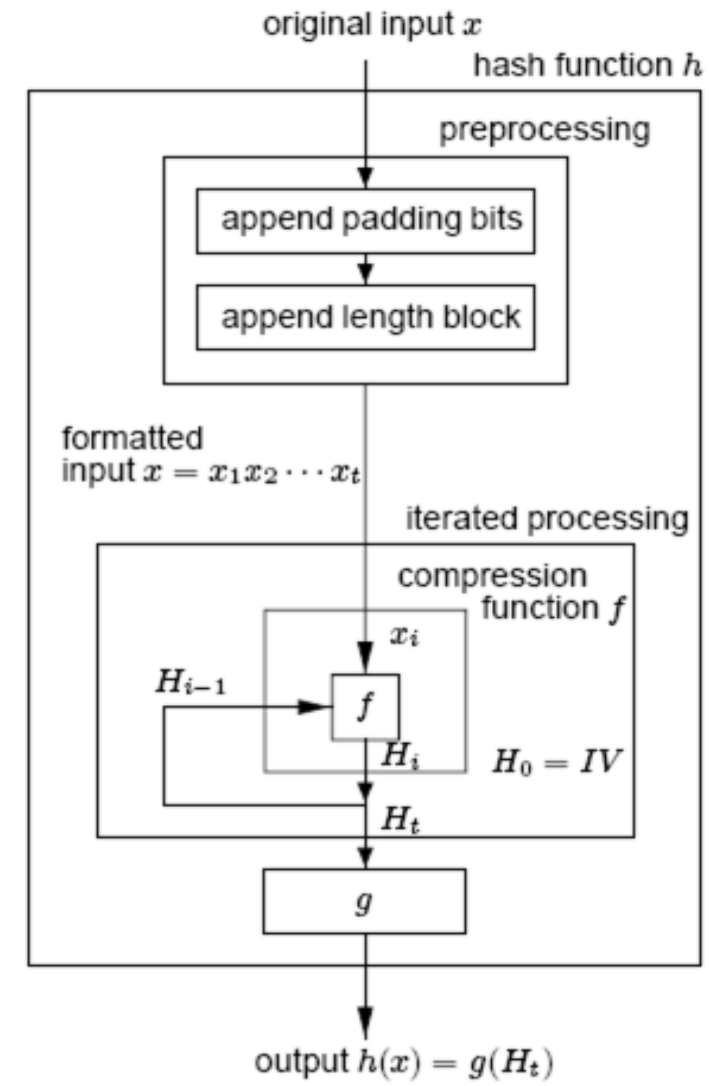
- Ausgabe des Hashwerts von m :

$$H(m) := g(t_n)$$

(a) high-level view



(b) detailed view



See: Handbook of Applied Cryptography,
Chapter 9

Kompressionsfunktion $f : \mathbb{Z}_2^{r+s} \rightarrow \mathbb{Z}_2^s$

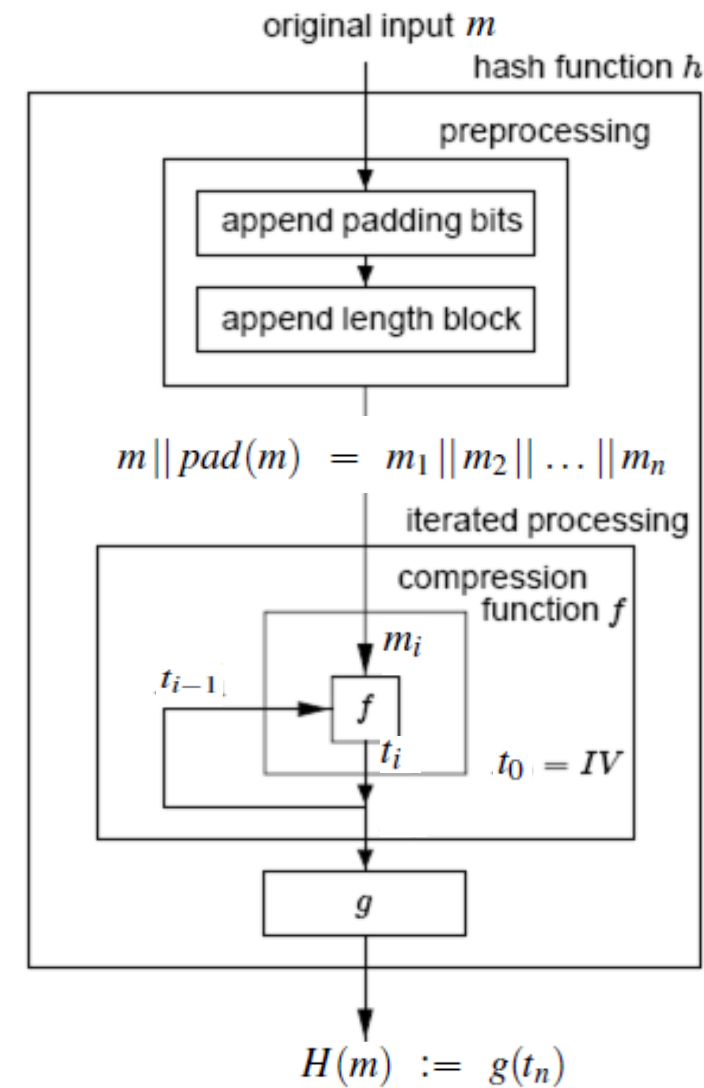
Ausgabefunktion $g : \mathbb{Z}_2^s \rightarrow \mathbb{Z}_2^l$

$$m \parallel pad(m) = m_1 \parallel m_2 \parallel \dots \parallel m_n$$

$$t_i := f(m_i \parallel t_{i-1}) \quad \text{für } i = 1, 2, \dots, n$$

$$H(m) := g(t_n)$$

(b) detailed view



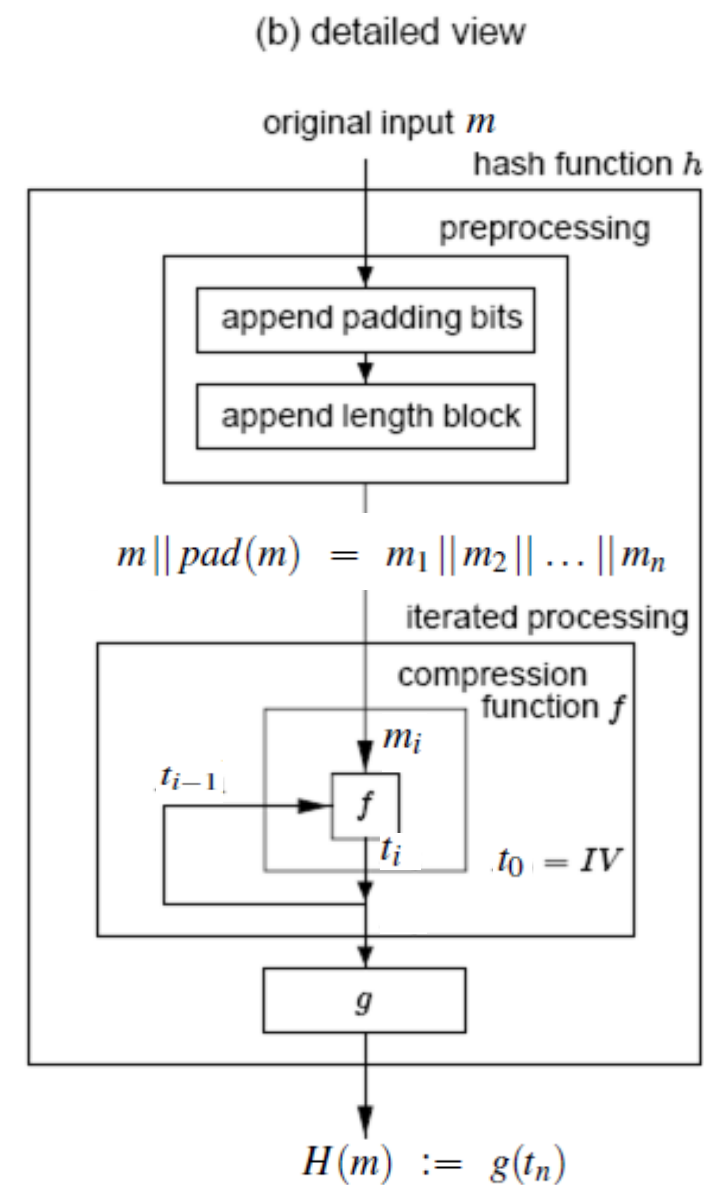
$$l(m_1) = \dots = l(m_n) = r$$

$$f : \mathbb{Z}_2^{r+s} \rightarrow \mathbb{Z}_2^s$$

$$t_i := f(m_i \parallel t_{i-1})$$

$$g : \mathbb{Z}_2^s \rightarrow \mathbb{Z}_2^l$$

H	$l = l(H(m))$	$r = l(m_i)$	$s = l(t_i)$	$\min\{l(pad)\}$
MD5	128	512	128	65
SHA-1	160	512	160	65
SHA-224	224	512	256	65
<u>SHA-256</u>	256	512	256	65
SHA-512/224	224	1024	512	129
SHA-512/256	256	1024	512	129
SHA-384	384	1024	512	129
<u>SHA-512</u>	512	1024	512	129
SHA3-224	224	1152	1600	4
SHA3-256	256	1088	1600	4
SHA3-384	384	832	1600	4
SHA3-512	512	576	1600	4



$$l(m_1) = \dots = l(m_n) = r$$

$$f: \mathbb{Z}_2^{r+s} \rightarrow \mathbb{Z}_2^s$$

$$t_i := f(m_i || t_{i-1})$$

$$g: \mathbb{Z}_2^s \rightarrow \mathbb{Z}_2^l$$

- BLAKE2
 - *BLAKE2: simpler, smaller, fast as MD5* (*Cryptology ePrint Archive, 2013*)
 - RFC 7693
- BLAKE3
- ...

- GHASH (Galois-Hash)
 - siehe NIST SP 800-38D (Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC), aber:
 - GHASH is a keyed hash function but not, on its own, a cryptographic hash function. This Recommendation only approves GHASH for use within the context of GCM.

- ✓ ■ **Kryptographisch sichere Pseudozufallszahlengeneratoren**
Cryptographic Secure Pseudo Random Number Generators (CSPRNG)
- ✓ ■ **Kryptographische Hashfunktionen**
Message Digests (Cryptographic Hash Functions)
- ✓ ■ **Symmetrische Verschlüsselungsverfahren** (symmetric ciphers)
 - **Message Authentication Codes (MACs)**
 - **Asymmetrische Verschlüsselungsverfahren** (asymmetric ciphers)
 - **Digitale Signaturen** (digital signatures)
 - **Schlüsselaustauschverfahren** (key exchange / key establishment)

- DC-02, Kap. 5:

MAC-Verfahren

5.1	HMAC	72
5.2	CMAC, CBC-MAC	74



- *Synonym für MAC-Verfahren: **Keyed Hashfunction***

Gegeben sei eine Nachrichtenmenge

$$\mathcal{M} = \mathcal{Z}^{\geq 0} \text{ oder } \mathcal{M} = \mathcal{Z}^{\leq N} \text{ mit } \mathcal{Z} = \underline{\mathbb{Z}_2^8}$$

und ein Schlüsselraum:

$$\mathcal{K}$$

Eine Abbildung

$$M : \mathcal{K} \times \mathcal{M} \rightarrow \mathbb{Z}_2^l$$

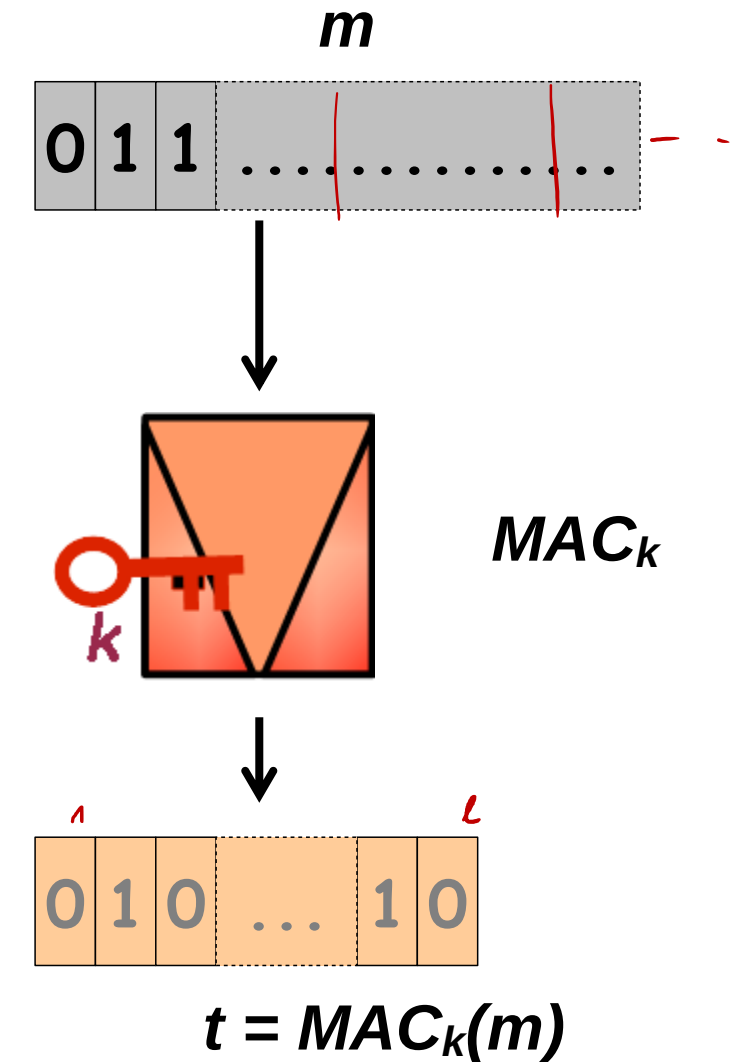
mit einem festen $l \in \mathbb{N}$ wird *MAC-Verfahren* genannt, falls ohne Kenntnis eines Schlüssels $k \in \mathcal{K}$ die Berechnung eines MAC-Wertes

$$t = M_k(m) := M(k, m)$$

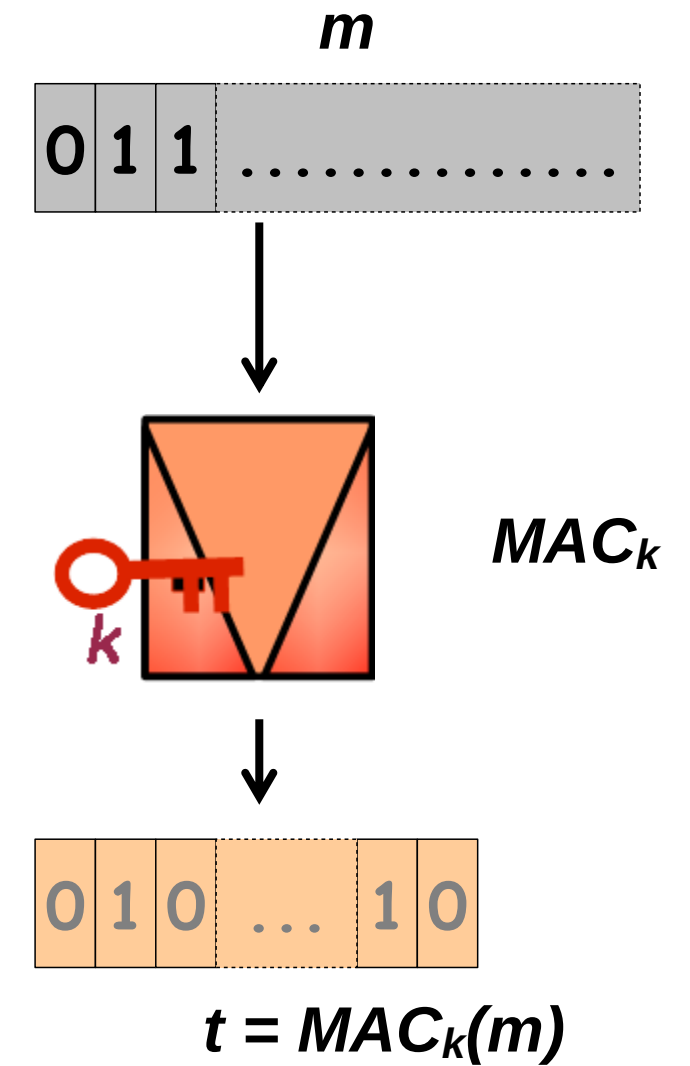
für keine Nachricht $m \in \mathcal{M}$ möglich ist. Dies soll effizient auch dann nicht möglich sein, falls bereits andere Paare

$$(m_i, t_i) \text{ mit } t_i = M_k(m_i)$$

bekannt sind.



Um einen Schutz gegen *chosen message attacks* gewährleisten zu können, wird zusätzlich gefordert, dass M_k für jedes $k \in \mathcal{K}$ die Eigenschaften einer kryptographischen Hashfunktion besitzt.



- Nachrichtenauthentizität innerhalb einer geschlossenen Gruppe von Kommunikationsteilnehmern mit einem gemeinsamen Schlüssel (secret key).

- Funktionsbausteine zur Konstruktion von:
 - KDFs
 - PBKDF
 - HKDF
 - CSPRNGs (Beispiel: HMAC_DRBG)
 - ...

HMAC-Verfahren (Keyed-Hashing for Message Authentication)

Jede Hashverfunktion h , die auf Grundlage einer Kompressionsfunktion definiert ist (s. Abschnitt 4.5), kann mit der in RFC 2104 (HMAC: Keyed-Hashing for Message Authentication) spezifizierten Konstruktion zu einem MAC-Verfahrens erweitert werden.

Ausgehend von einer Hashfunktion H mit einer Kompressionsfunktion wie in (4.1)

$$f : \mathbb{Z}_2^{r+s} \rightarrow \mathbb{Z}_2^s$$

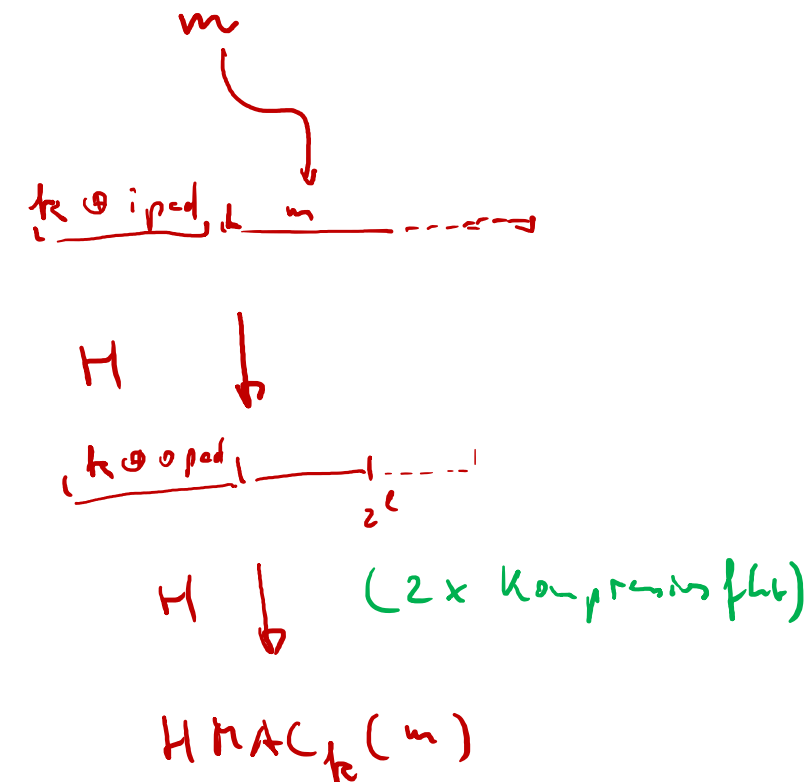
mit Eingabeblocks der Bitlänge r (mit $r \bmod 8 = 0$) ist das MAC-Verfahren $M = \text{HMAC-}H$ definiert durch:

$$M_k(m) := H\left((k \oplus \text{opad}) || H((k \oplus \text{ipad}) || m)\right) \quad (5.1)$$

Hierbei sind opad und ipad fest definierte Bytearrays der Bytelänge $r/8$. Deren konkrete Werte und weitere Details können der Beispielimplementierung aus Abbildung 5.1 entnommen werden.

RFC 2104 - Keyed-Hashing for Message Authentication

- Hash function H , using a compression function which compresses r_b bytes from the input per round. (E.g.: $r_b = 64$ for SHA-256)
- Hash output length h_b in bytes ($h_b = 32$ für SHA-256)
- $HMAC(m) = H(\underbrace{k \text{ XOR opad}}_{\text{m}} \mid \underbrace{H(\underbrace{k \text{ XOR ipad}}_{\text{m}} \mid \underline{m})}_{\text{m}})$
 $ipad = 0x36 \mid 0x36 \mid \dots \mid 0x36$ (r_b Bytes)
 $opad = 0x5c \mid 0x5c \mid \dots \mid 0x5c$ (r_b Bytes)

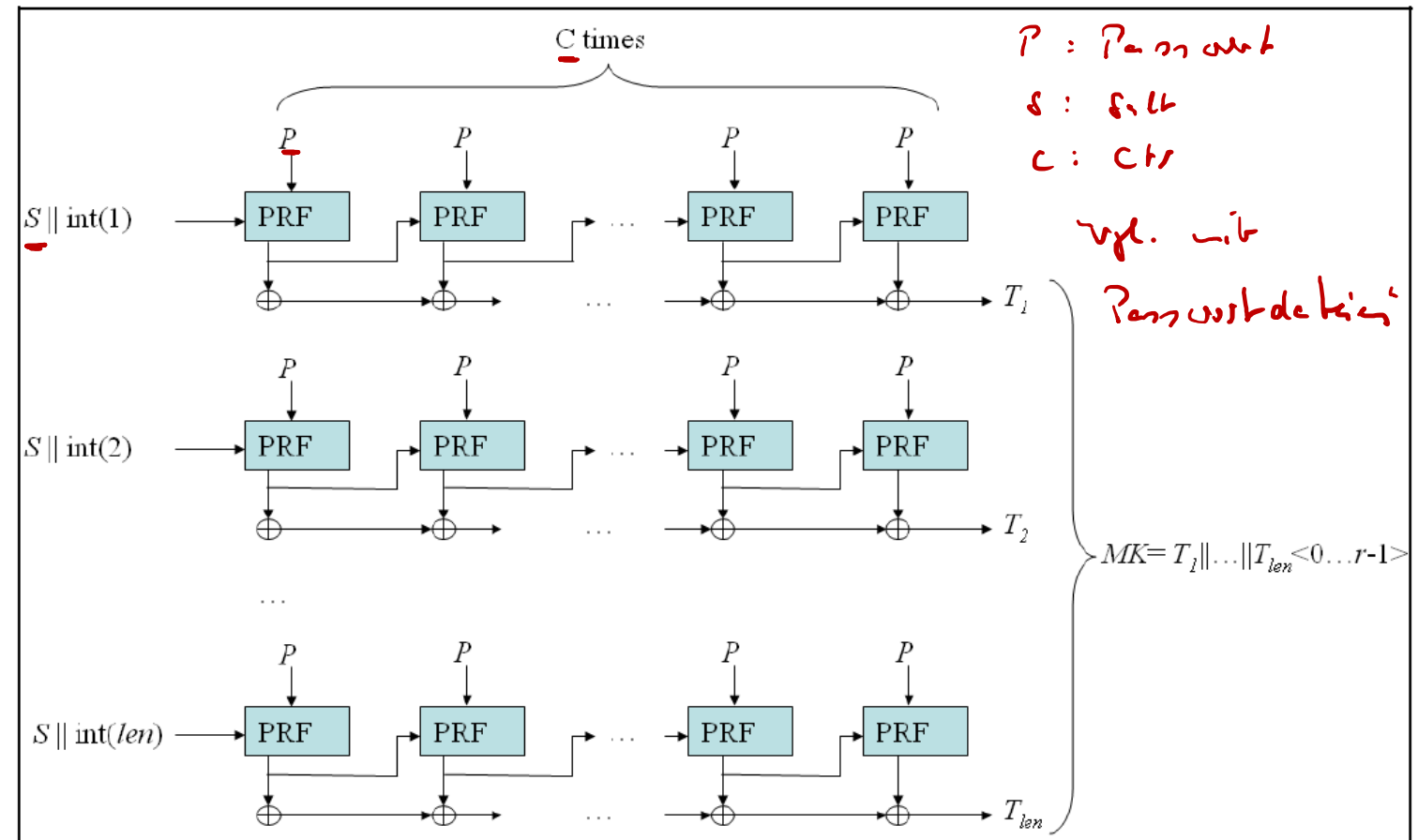


```
33
34 public static void main(String[] args) throws Exception {
35     byte[] key = Dump.hexString2byteArray(""
36         + "17b52858e3e135be4440d7df0ca996f41ccb78b7"
37         + "d8cc1924d830fe81e0fd279c131ce3546303e95a");
38     byte[] msg = "Testnachricht".getBytes();
39
40     SecretKey secretKey = new SecretKeySpec(key, "HmacSHA256"); ←
41
42     Mac mac = Mac.getInstance("HmacSHA256");
43     mac.init(secretKey);
44     byte[] macValue = mac.doFinal(msg);
45
46     System.out.println("MAC value:");
47     System.out.println(Dump.dump(macValue));
48 }
```

← ursprünglich RSA Labs

- [RFC 8018](#) - [PKCS #5](#): Password-Based Cryptography Specification Version 2.1
- [NIST SP 800-132](#) - NIST Special Publication 800-132 Recommendation for Password-Based Key Derivation: Part 1: Storage Applications

- Figure 2: A general diagram of the PBKDF:
- This Recommendation approves PBKDF2 as the PBKDF using HMAC with any **approved** hash function as the PRF.



RFC 5869 - HMAC-based Extract-and-Expand Key Derivation Function (HKDF)

- HKDF-Extract(salt, IKM) -> PRK
- HKDF-Expand(PRK, info, L) -> OKM
- Used in TLS 1.3 for key derivations, see [RFC 8446, 7.1](#).

7.1. Key Schedule

The key derivation process makes use of the HKDF-Extract and HKDF-Expand functions as defined for HKDF [RFC5869], as well as the functions defined below:

TLS Def: $\rightarrow$ `HKDF-Expand-Label(Secret, Label, Context, Length) =`
 `HKDF-Expand(Secret, HkdfLabel, Length)`

Where HkdfLabel is specified as:

```
struct {  
    uint16 length = Length;  
    opaque label<7..255> = "tls13 " + Label;  
    opaque context<0..255> = Context;  
} HkdfLabel;
```

$\leftarrow$ TLS (Hash aller zuvor angestandter Nachrichten)

TLS:

```
Derive-Secret(Secret, Label, Messages) =  
    HKDF-Expand-Label(Secret, Label,  
        Transcript-Hash(Messages), Hash.length)
```

RFC 5869 - HMAC-based Extract-and-Expand Key Derivation Function (HKDF)

■ 2.2. Step 1: Extract

HKDF-Extract(salt, IKM) -> PRK

Options:

Hash a hash function; HashLen denotes the length of the
hash function output in octets

Inputs:

salt optional salt value (a non-secret random value);
if not provided, it is set to a string of HashLen zeros.
IKM input keying material

Output:

PRK a pseudorandom key (of HashLen octets)

The output PRK is calculated as follows:

PRK = HMAC-Hash(salt, IKM)

RFC 5869 - HMAC-based Extract-and-Expand Key Derivation Function (HKDF)

■ 2.3. Step 2: Expand

HKDF-Expand(PRK, info, L) -> OKM

Options:

Hash a hash function; HashLen denotes the length of the hash function output in octets

Inputs:

PRK a pseudorandom key of at least HashLen octets
 (usually, the output from the extract step)

info optional context and application specific information
 (can be a zero-length string)

L length of output keying material in octets
 (<= 255*HashLen)

Output:

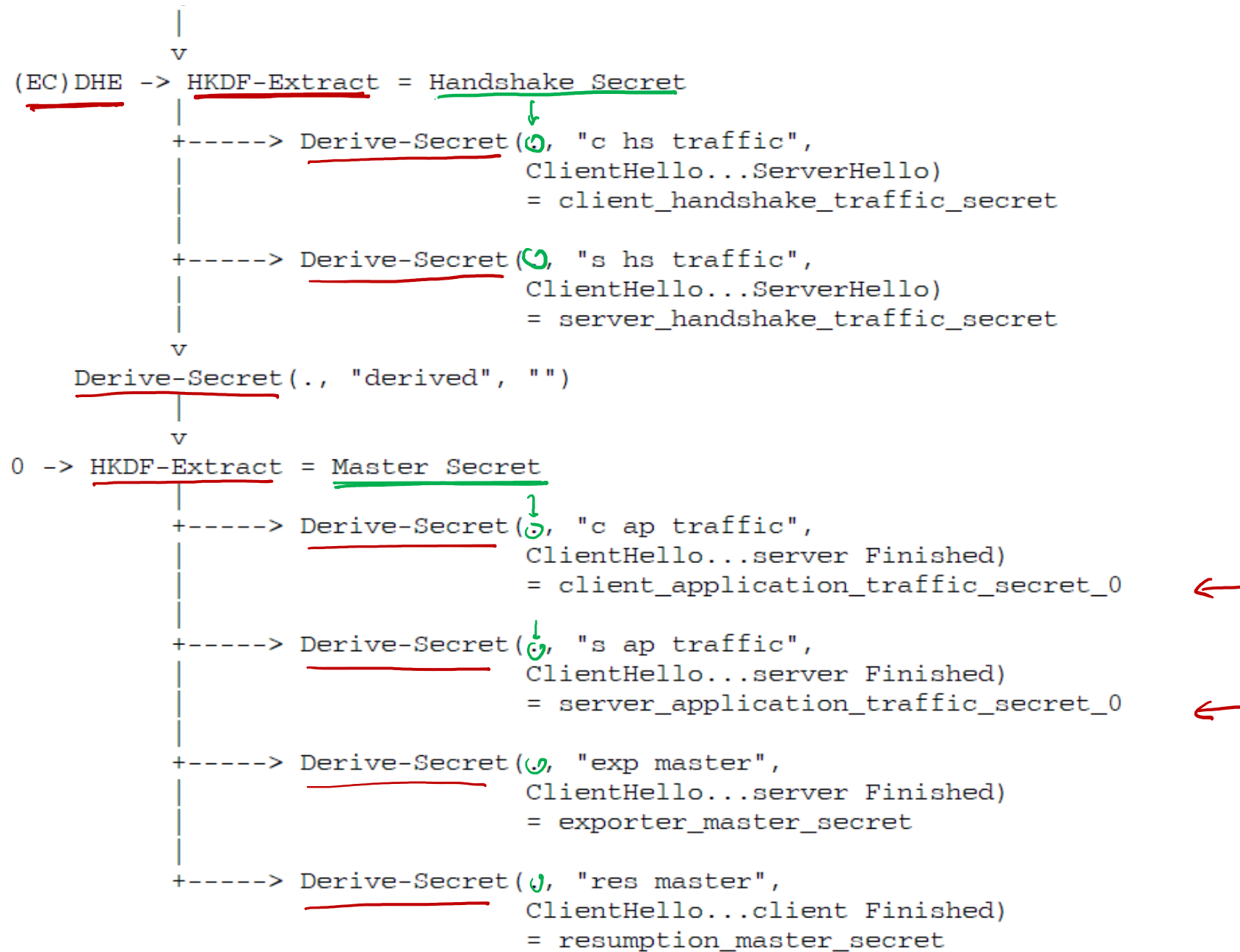
OKM output keying material (of L octets)

The output OKM is calculated as follows:

$N = \text{ceil}(L/\text{HashLen})$
 $T = T(1) \mid T(2) \mid T(3) \mid \dots \mid T(N)$
OKM = first L octets of T

where:

$T(0)$ = empty string (zero length)
 $T(1)$ = HMAC-Hash(PRK, $T(0)$ | info | 0x01)
 $T(2)$ = HMAC-Hash(PRK, $T(1)$ | info | 0x02)
 $T(3)$ = HMAC-Hash(PRK, $T(2)$ | info | 0x03)
...



■ RFC 6238 - Time-Based One-Time Password Algorithm

TH OWL Zwei Faktor Verwaltung TH OWL

One-Time Authentication Code (TOTP)

Obtain device-generated TOTP

331875

Hide

Next Cancel

Click here if you've forgotten your username or password, or if you need to register.

Copyright © 2023 Micro Focus. All rights reserved.

20:35 47%

Verbinden Sie sich mittels des generierten TOTP (zeitbezogenes Einmalpasswort) mit einer Anwendung.

Zeitbezogenes Einmalpasswort (TOTP)

abc-xyz

933903 neuer Code in 18 s

Zeitbezogenes Einmalpasswort (TOTP)

@th-owl.de

331875 neuer Code in 18 s

+

■ RFC 6238 - Time-Based One-Time Password Algorithm

```
135  /**
136   * TOTP algorithm as specified in RFC 6238 with default values for the
137   * time step parameter X = 30 s and for the
138   * Unix time to start counting time steps T0 = 0.
139   *
140   * @param key
141   * @return TOTP
142   */
143  static String totp(byte[] key) throws Exception {
144      // T = (Current Unix time - T0) / X
145      long t = System.currentTimeMillis() / 30000;
146      return hotp(key, t);
147  }
```

■ RFC 4226 - HOTP: An HMAC-Based One-Time Password Algorithm

```
115 static String hotp(byte[] key, long ct, int digit)
116     throws NoSuchAlgorithmException, InvalidKeyException {
117     SecretKey secretKey = new SecretKeySpec(key, "HmacSHA1");
118     Mac mac = Mac.getInstance("HmacSHA1");
119     mac.init(secretKey);
120
121     byte[] msg = new byte[8];
122     for (int i = 7; i >= 0; --i) {
123         msg[i] = (byte) (ct & 0xff);
124         ct >>= 8;
125     }
126     byte[] hs = mac.doFinal(msg);
127
128     int offset = hs[19] & 0xf;
129     int p = (hs[offset] & 0x7f) << 24 | (hs[offset + 1] & 0xff) << 16
130         | (hs[offset + 2] & 0xff) << 8 | (hs[offset + 3] & 0xff);
131
132     return String.format("%0" + digit + "d", p % Math.round(Math.pow(10, digit)));
133 }
```

20 Byte

$\in \{0, 1, \dots, 15\}$

- [RFC 4226](#) - HOTP: An HMAC-Based One-Time Password Algorithm
- Shared secret between client and server:



otpauth://totp/Netiq?secret=AEBAGBAFAYDQQCIQCEJBGFAVCYLRQGJA&issuer=Netiq

00000001|00000001|00000000
x 01 02

- [RFC 4648](#) - The Base16, Base32, and Base64 Data Encodings

Table 3: The Base 32 Alphabet

Value	Encoding	Value	Encoding	Value	Encoding	Value	Encoding
0	A	9	J	18	S	27	3
1	B	10	K	19	T	28	4
2	C	11	L	20	U	29	5
3	D	12	M	21	V	30	6
4	E	13	N	22	W	31	7
5	F	14	O	23	X		
6	G	15	P	24	Y	(pad)	=
7	H	16	Q	25	Z		
8	I	17	R	26	2		